Phishing and Ransomware Scenario Simulation Lab

OPERATIONAL RUNBOOK

Table of Content

1. Objective
2. Lab Architecture
    - 2.1 Virtual Machines
    - 2.2 Networking
3. Pre-Execution Checklist
4. Services Startup
5. Phishing Campaign Execution
6. Payload Execution (Benign Ransomware)
7. Evidence Collection
8. Analysis
9. Recovery and Cleanup
10. Safety and Ethics
11. Known Limitations
12. Conclusion

1. Objective

To analyze and execute a phishing-based attack that escalates into a benign ransomware simulation within an isolated virtual lab environment, while capturing host and network evidence.

2. Lab Architecture

Virtual Machines

- Windows 10 Pro – Victim (Thunderbird user: Emily)
- Debian 12 – Utility Server (Dovecot, Postfix, Suricata, tcpdump)
- Kali Linux – Attacker (Gophish)

Networking

- Host-only network for inter-VM communication
- NAT network for updates and installations

3. Pre-Execution Checklist

- ✓ All VMs powered on
- ✓ Host-only IP connectivity verified
- ✓ Snapshots taken (Pre-Attack)
- ✓ Services installed and configured

4. Services Startup

Debian Utility VM

→ sudo systemctl start dovecot
→ sudo systemctl start postfix
→ sudo systemctl start suricata

Verify:

→ sudo systemctl status dovecot postfix suricata

Kali Linux (Gophish)

→ sudo apt install gophish
→ sudo gophish

5. Phishing Campaign Execution

- ✓ Configure sending profile (SMTP relay via Debian)
- ✓ Create email template
- ✓ Create landing page
- ✓ Add target user (Emily)
- ✓ Launch campaign

Verification:

- ✓ Email received in Thunderbird
- ✓ Campaign status visible in Gophish

6. Payload Execution (Benign Ransomware)

Windows (Victim):

Open Powershell

→ Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass .\simulate_ransom.ps1

Expected results:

- Files locked in Documents and Desktop
- Ransom note created

7. Evidence Collection

Windows

- Locked files and ransom note
- Powershell output

- Event Viewer logs:
  -Security
  -Powershell
  -Sysmon (If available)

Debian

→ sudo journalctl -u postfix > postfix.log
→ sudo journalctl -u dovecot > dovecot.log
→ sudo cp /var/log/suricata/fast.log suricata.log

Network Capture

→ sudo tcpdump –i interface –w nameofpcap.pcap

8. Analysis

PCAP Analysis

→ Wireshark attack_capture.pcap

Inspect:

- SMTP (email delivery)
- IMAP (mail access)
- HTTP (landing page interaction)

Timeline Reconstruction

Correlate timestamps from:

- Gophish campaign logs
- Postfix and Dovecot logs
- Windows logs
- PCAP traffic

9. Recovery and Cleanup

✓ Restore VM snapshots

- ✓ Archive logs and screenshots
- ✓ Stop Gophish
- ✓ Shut down lab environment

10. Safety and Ethics

- No real malware deployed
- All actions performed in isolated VMs
- Simulation is reversible
- Lab used strictly for educational purposes

11. Known Limitations

- Limited Sysmon visibility due to VM constraints
- No Domain Controller or centralized logging
- Logical evidence collection used instead of full disk imaging

Conclusion

This runbook provides a repeatable operational reference for executing and analyzing a phishing-based ransomware simulation. It supports incident response training, log analysis, and forensic reasoning within a constrained but realistic lab environment. The runbook also acknowledges practical limitations such as system resource constraints and partial logging visibility, reflecting realistic operational challenges. Overall, it serves as both an execution guide and a learning resource that supports incident response preparedness and can be expanded in future to include improved detection coverage and automation.